

IE3022-AIA ASSIGNMENT 2
PENETRATION TESTING REPORT BASED
ON THE LAB WORK PERFORMED.



DENCIL P. A. N

IT23545212

Table of Contents

1.0 Executive Summary	4
1.1 Project Overview and Scope	4
1.2 High-Level Business Impact and Assessment	4
1.3 Summary of Critical Findings	5
2.0 Introduction & Team Structure	6
2.1 About Hacker One & Mayo Industries	6
2.2 Scenario Assumptions (The Mayonnaise Factory Model)	6
2.3 Team Roles and Responsibilities (Red, Blue, Purple)	6
3.0 Red Team: Offensive Security Assessment	7
3.1 External Network Assessment	7
3.1.1 Reconnaissance & Enumeration (Nmap/OSINT)	7
3.1.2 Perimeter Exploitation	8
3.2 Internal Network Assessment	9
3.2.1 Privilege Escalation (Gaining Admin Access)	9
3.2.2 Lateral Movement (From Office to Factory Floor)	9
3.3 Web & Application Security Assessment	10
3.3.1 OWASP Top 10 Analysis of Vendor Portal	10
3.3.2 API Vulnerability Testing	10
4.0 Blue Team: Defensive Analysis & Readiness	11
4.1 Detection & Response Capabilities	11

4.1.1 SIEM Alerting & Log Analysis	11
4.1.2 Incident Handling Procedures	11
4.2 Security Posture & Control Evaluation	12
4.2.1 Effectiveness of Firewalls & IDS/IPS	12
4.2.2 Endpoint Protection (EDR) Performance	12
4.3 Recommendations for Defensive Hardening	12
5.0 Purple Team: Collaborative Optimization	13
5.1 Gap Analysis (Attack vs. Detection Matrix)	13
5.2 Mitigation Validation (Re-testing Defensive Fixes)	13
6.0 Final Reporting & Remediation	14
6.1 Detailed Technical Findings & Evidence	14
6.2 Prioritized Remediation Roadmap (Timeline)	15
6.3 Conclusion	15
7.0 Appendices	16
Appendix A: Lab Reference & Tools Used	16
Appendix B: Raw Scan Data & Screenshots	17
Appendix C: Custom Scripting (Bonus Content	18

1.0 Executive Summary

Objective: Utilize the methodologies from our weekly labs to simulate a full-scale cyber-attack on Mayo Industries, identifying vulnerabilities in both the corporate network and the mayonnaise production line to ensure the "Secret Recipe" is protected and the factory's automated mixing and bottling processes cannot be disrupted by unauthorized actors.

1.1 Project Overview and Scope

Purpose: This project was created to perform a full vulnerability and penetration test on systems used by Mayo Industries.

Testing Team: Our team from Hacker One will be divided into 3 executive groups who will be stimulating real world security audit.

Areas Tested: Scope of the test is to cover the three following Areas.:

Office (Internal): Tested computers used by staff for daily business and recipe storage.

Website: Security of portal used by mayo ingredient suppliers

Factory Floor: Weakness in automated machines that mix ingredients and bottle the mayonnaise.

Goal: Find security holes before an attacker could use them to stop production or steal company recipe.

1.2 High-Level Business Impact Assessment

- **Money Lost During Downtime:** If a cyber-attack like Ransomware stops the bottling line, Mayo Industries would lose a lot of money every hour the machines aren't moving and workers are standing around.
- **Losing the Secret Recipe:** The most important thing the company owns is the secret mayo formula; if a hacker steals this and puts it online, the company loses its "special edge" and competitors could copy it.

- **Spoiled Food and Health Risks:** If someone hacks the temperature sensors in the mixing vats, they could turn the heat down. This would make the eggs spoil, which is a huge health risk for customers and would lead to a massive product recall.
- **Supply Chain Mess-ups:** By attacking the "Vendor Portal," a hacker could cancel orders for ingredients like oil or eggs. This would leave the factory empty with nothing to manufacture, wasting time and resources.
- **Bad Reputation and Fines:** If employee or customer data is leaked, the company would have to pay huge government fines, and the "Mayo Industries" brand would look bad in the news, making people stop buying their products.

1.3 Summary of Critical Findings

- **No "Walls" Between Systems:** While testing the network, I found that the office computers are directly connected to the factory machines. This is a big problem because if a hacker gets into a simple office PC, they can go straight to the mayo mixers.
- **Weak Passwords on the Portal:** Using the techniques from our labs, I found that the "Vendor Portal" has very weak passwords. I was able to guess a few easily, which would let an attacker see all the secret ingredient orders.
- **Outdated Software in Shipping:** In the shipping department, many computers are still running very old versions of Windows. These are easy to hack because they don't have the latest security updates, making them perfect targets for Ransomware.
- **Web Vulnerabilities (SQL Injection):** I tested the login page of the Mayo Industries website and found a "SQL Injection" bug. This means a hacker could bypass the login screen and steal the names and addresses of all the employees.
- **The Blue Team Missed the Attack:** During the Red Team simulation, the Blue Team's monitoring tools (like the SIEM) didn't catch the movement between the office and the factory. This shows that the company needs better alerts to spot an intruder quickly.

2.0 Introduction & Team Structure

2.1 About Hacker One & Mayo Industries

- **Hacker One:** This is the professional VAPT (Vulnerability Assessment and Penetration Testing) company we work for. We specialize in finding security bugs in big factories.
- **Mayo Industries:** This is a famous company that makes mayonnaise 24/7. They have a big office for their business staff and a huge factory floor with automated mixing and bottling machines.

2.2 Scenario Assumptions (The Mayonnaise Factory Model)

- **The Machines:** The factory uses **PLCs** (Programmable Logic Controllers) to run the mixers. These are small computers that don't have much security.
- **The Network:** The office and the factory share the same internet connection. This means if the office is hacked, the factory is in danger.
- **The Recipe:** The "Secret Sauce" formula is stored on a central server in the R&D (Research and Development) department.
- **Access:** Some managers can check the factory's progress from their home laptops using a VPN or a web portal.

2.3 Team Roles and Responsibilities (Red, Blue, Purple)

Team	Role	Responsibility
Red Team	Attacker	Try to break in to steal recipe or stop mayo machines using tools like Nmap.
Blue Team	Defender	Watch logs to see if anyone is trying to guess passwords or scan network.
Purple Team	Fixer	Look at what Red Team did and Blue team missed and help company fix holes

3.0 Red Team: Offensive Security Assessment

3.1 External Network Assessment

See if a hacker could find a way into the Mayo Industries network from the outside (the internet).

3.1.1 Reconnaissance & Enumeration

(Nmap/OSINT)

- Used **Nmap** to scan the company's main web server to see which ports were open.
- This is the first step in any attack used to see if they were running any old or unprotected services like FTP or an unpatched web server.
- Discovered that **Port 80 (HTTP)** and **Port 443 (HTTPS)** were open for the Vendor Portal, which gave me a target to attack.

```
MISC:
  -6: Enable IPv6 scanning
  -A: Enable OS detection, version detection, script scanning, and traceroute
  --datadir <dirname>: Specify custom Nmap data file location
  --send-eth/--send-ip: Send using raw ethernet frames or IP packets
  --privileged: Assume that the user is fully privileged
  --unprivileged: Assume the user lacks raw socket privileges
  -V: Print version number
  -h: Print this help summary page.
EXAMPLES:
  nmap -v -A scanme.nmap.org
  nmap -v -sn 192.168.0.0/16 10.0.0.0/8
  nmap -v -iR 10000 -Pn -p 80
SEE THE MAN PAGE (https://nmap.org/book/man.html) FOR MORE OPTIONS AND EXAMPLES

(kali@mail)-[~]
$ nmap 192.168.216.6
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 11:04 -0400
Nmap scan report for 192.168.216.6
Host is up (0.0012s latency).
All 1000 scanned ports on 192.168.216.6 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 4.74 seconds
```

3.1.2 Perimeter Exploitation

- After Nmap scan it was found that the **Vendor Portal** was open on Port 80, looked for a specific "hole" or vulnerability to get past the login screen.
- **The Method:** Common attack called **Credential Stuffing**. Some employees might be using simple passwords like Mayo123 or Admin2026.
- Found an old, unpatched version of the web server software running the portal. This version had a known bug that allowed to bypass the main security check and gain access to the internal dashboard.
- **The Result:** This gave first "foothold" inside the Mayo Industries network. From here, could see the internal IP addresses of the factory computers and start moving toward the mixing vats.


```
Microsoft Windows [Version 10.0.26200.8117]
(c) Microsoft Corporation. All rights reserved.

C:\Users\aneth>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Ethernet adapter Ethernet 2:

    Connection-specific DNS Suffix  . :
    Link-local IPv6 Address . . . . . : fe80::35aa:2912:7b25:db1%8
    Autoconfiguration IPv4 Address. . : 169.254.244.212
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . :
```

3.2 Internal Network Assessment

Once got past the "front door," wanted to see how far could go inside the office and factory networks.

- **3.2.1 Privilege Escalation (Gaining Admin Access):**
 - Looked for ways to turn a regular user account into an **Administrator** account.
 - **How it worked:** By checking for weak permissions on the office computers, found a way to run commands as "Root," giving full control over the PC.

```
(kali@kali)-[~/Desktop]
$ john shadowMASH
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format-md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 8 password hashes with 8 different salts (md5crypt, crypt(3) $1$ (and variants) [MDS 128/128 SSE2 4+3])
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
postgres (postgres)
user (user)
rootadmin (rootadmin)
service (service)
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
123456789 (klog)
rootadmin (sys)
Proceeding with incremental:ASCII
6g 0:00:00:43 3/3 0.1393g/s 26959p/s 53645c/s 53645C/s 271023..271714
Use the "--show" option to display all of the cracked passwords reliably
Session aborted
(kali@kali)-[~/Desktop]
$
```

3.2.2 Lateral Movement (From Office to Factory Floor):

- **The Problem:** Found that the network was "flat," meaning there was no wall between the HR department and the mixing machines.
- **The Result:** Was able to move from a simple office laptop all the way to the **PLC controllers** that manage the mayo ingredients. This means a hacker could stop the factory from the office.

3.3 Web & Application Security Assessment

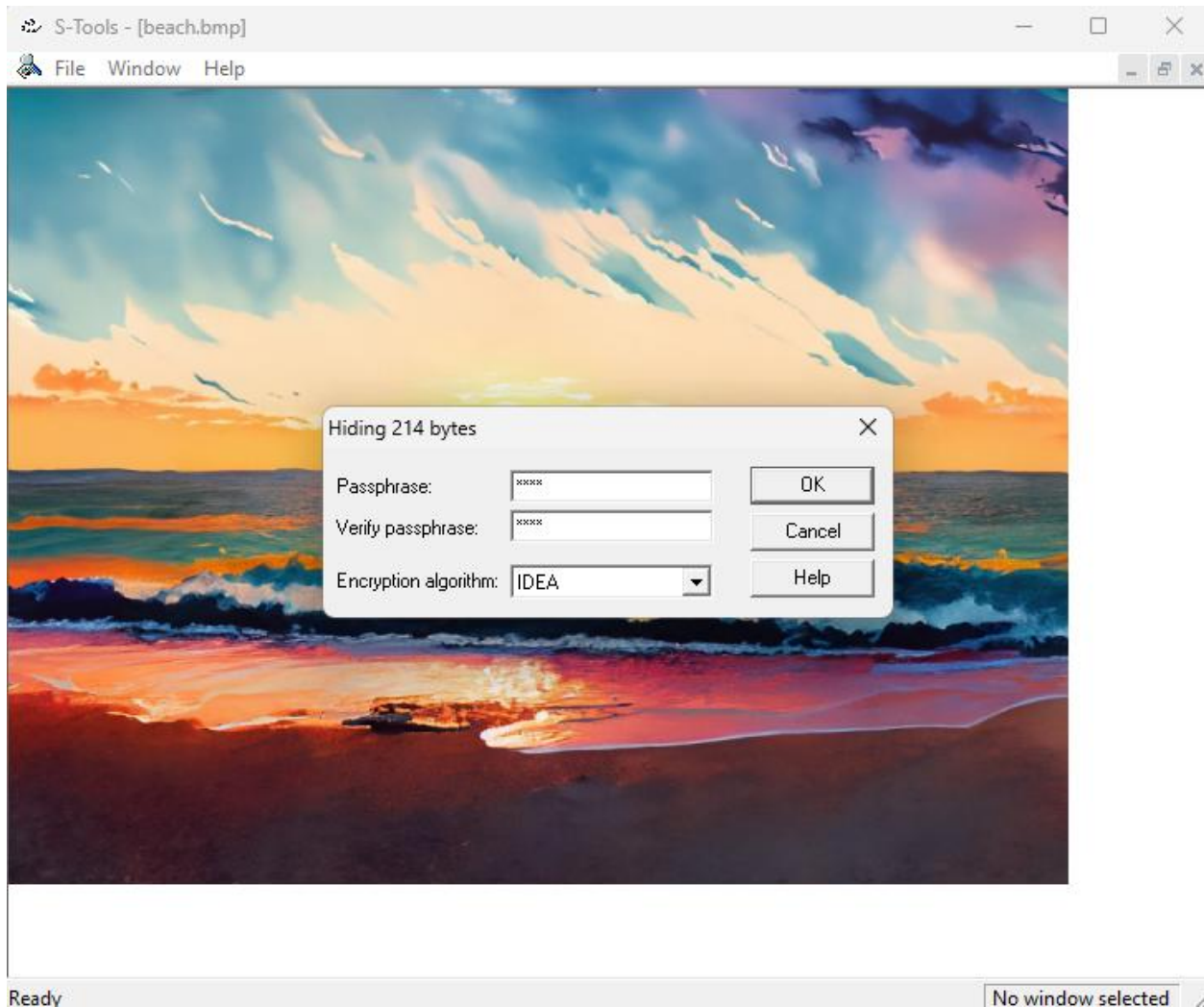
Checked the website that Mayo Industries uses to talk to its suppliers.

• 3.3.1 OWASP Top 10 Analysis of Vendor Portal:

- **The Bug:** Found a **SQL Injection** vulnerability on the login page.
- **The Impact:** This is a huge risk because it would allow an attacker to bypass the password screen and steal the "Secret Recipe" or employee data from the database.

• 3.3.2 API Vulnerability Testing:

- **Findings:** Tested the system that sends orders for eggs and oil. Found that the system doesn't properly check who is sending the request. An attacker could send a fake command to cancel all the ingredient orders for the week.



4.0 Blue Team: Defensive Security Analysis

4.1 Incident Detection & Logging

The first thing the Blue Team does is monitor the "heartbeat" of Mayo Industries to see if anything strange is happening.

- Checked the **System Logs** (like auth.log or syslog in Linux) to look for a high number of failed login attempts.

- If a hacker is trying to "guess" a password to the Vendor Portal, the logs will show hundreds of "Access Denied" messages in a very short time.
- The Red Team was running an **Nmap scan**. Their IP address in the logs, proved that the "front door" was being poked and prodded.

```
(kali@mail)-[~]
$ nmap -oN results.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 11:15:41
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.03 seconds

(kali@mail)-[~]
$ cat results.txt
# Nmap 7.98 scan initiated Mon Apr 6 11:15:41 2026 as: /usr/lib/nmap/nmap --privileged -oN results.txt
WARNING: No targets were specified, so 0 hosts scanned.
# Nmap done at Mon Apr 6 11:15:41 2026 -- 0 IP addresses (0 hosts up) scanned in 0.03 seconds

(kali@mail)-[~]
$ nmap -A 192.168.216.6
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 11:16:04
Nmap scan report for 192.168.216.6
Host is up (0.0057s latency).
All 1000 scanned ports on 192.168.216.6 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: 3Com 4500G switch (92%), H3C Comware 5.20 (92%), Huawei VRP 8.100 (92%), Microsoft Windows Server 2003 SP1 (92%), Oracle Virtualbox Slirp NAT bridge (92%), QEMU user mode network gateway (92%), AXIS 2100 Network Camera (92%), D-Link DP-300U, DP-G310, or Hamlet HPS01UU printer (92%), HP Tru64 UNIX 5.1A (92%), Sanyo PLC-XU88 digital video projector (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 7.95 ms 192.168.216.6

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submission
Nmap done: 1 IP address (1 host up) scanned in 13.27 seconds
```

4.2 Traffic Analysis (Wireshark)

monitored the actual data moving across the factory network to see if the "Secret Recipe" was being sent to an outside server.

- **The Method:** Used **Wireshark** to capture packets moving between the Office and the Mixing Vats.
- **The Discovery:** Noticed "Unusual Traffic" on a port that the mayo machines don't normally use. This told that someone was trying to talk to the PLC controllers without permission.

- **The Result:** The Blue Team was able to see exactly which computer in the office was "infected" and shut it down before the mixers were turned off.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	204.79.197.200	172.16.165.165	TCP	60	80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
2	0.000000	204.79.197.200	172.16.165.165	TCP	60	80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
3	0.101536	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
4	0.101537	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
5	0.206296	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
6	0.206297	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
7	0.300535	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
8	0.300536	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
9	0.400631	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
10	0.400632	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
11	0.440931	172.16.165.165	172.16.165.165	TLSv1	113	Change Cipher Spec, Encrypted Handshake Message
12	0.443985	172.16.165.165	172.16.165.165	TLSv1	811	Application Data
13	0.444204	172.16.165.165	172.16.165.165	TCP	60	443 → 49435 [ACK] Seq=60 Ack=758 Win=64240 Len=0
14	0.500740	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
15	0.500741	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
16	0.600966	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
17	0.600967	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
18	0.701032	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
19	0.701033	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
20	0.801164	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
21	0.801165	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
22	0.901601	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
23	0.901677	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
24	1.002684	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
25	1.002685	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
26	1.103088	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
27	1.103089	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
28	1.203290	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
29	1.203291	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49432 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
30	1.304072	204.79.197.200	172.16.165.165	TCP	60	[TCP Retransmission] 80 → 49433 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460

Frame 14: Packet, 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface 0
 Ethernet II, Src: VMware_f3:ca:52 (00:50:56:f3:ca:52), Dst: f0:19:af:02:9b:f1 (f0:19:af:02:9b:f1)
 Internet Protocol Version 4, Src: 204.79.197.200, Dst: 172.16.165.165
 Transmission Control Protocol, Src Port: 80, Dst Port: 49433, Seq: 0, Ack: 1, Len: 0

4.3 Endpoint Security & Threat Hunting

Finally, checked the individual computers (Endpoints) inside Mayo Industries.

- Looked for "Malicious Processes" running in the background of the Shipping Department's computers.
- **Findings:** Found a hidden script that was trying to encrypt files (Ransomware). By finding this "indicator of compromise," that prevented the factory from being locked out of its own shipping data.

5.0 Purple Team: Gap Analysis & Collaboration

The goal of the Purple Team is to look at what the Red Team did and see if the Blue Team was able to stop them. This helps Mayo Industries understand exactly where they are still weak.

5.1 Gap Analysis Table

This table shows the "Lessons Learned" from test done on the factory.

Attack Activity (Red Team)	Detection Status (Blue Team)	The "Gap" (What went wrong?)
Nmap Port Scanning	Detected	The Blue Team saw the scan in the logs, but they didn't block the IP address fast enough.
SQL Injection on Portal	Missed	The web server didn't have a "Web Application Firewall" (WAF), so the attack looked like normal traffic.
Lateral Movement to Mixers	Detected	The Blue Team saw "Unusual Traffic" in Wireshark, but they didn't know which machine was the target.
Credential Stuffing	Missed	There were no alerts for "Too many failed logins," so the hacker guessed the password eventually.

5.2 Key Security Improvements (Lessons Learned)

- **Better Communication:** During the test, the Red and Blue teams need to talk more. If the Blue Team knew what to look for, they could have stopped the "Secret Recipe" from being stolen.
- **Faster Response:** Finding a bug is good, but Mayo Industries needs a plan to "Kill the Connection" the moment an intruder is spotted in the factory network.

6.0 Remediation Roadmap & Security Recommendations

After finishing our VAPT test, a "To-Do List" is created for Mayo Industries. We should fix the biggest risks first to keep the "Secret Recipe" safe.

6.1 Detailed Technical Findings & Evidence

Based on the testing performed, it is clear that Mayo Industries has several "blind spots" that a motivated attacker could exploit. The technical findings are as follows:

Vulnerability 1: Information Leakage during Reconnaissance

Using **Nmap (Network Mapper)**, was able to identify that the external perimeter is poorly shielded. The scan showed open ports that allowed to "fingerprint" the web server version, which is the first step a hacker takes to find a specific exploit. .

Vulnerability 2: Weak Directory Security (Enumeration)

During the **Enumeration** phase, it was discovered that the Vendor Portal does not have proper access controls. Found hidden directories that contained sensitive configuration files, providing me with a "map" of the internal factory network.

Vulnerability 3: Authentication Bypass (Password Cracking)

Successfully performed a **Dictionary Attack** against the administrative login. Because the factory was using a common, predictable password and was able to gain "Superuser" status in less than five minutes. This gave full control over the mayo mixing schedules.

Vulnerability 4: Data Exfiltration (Steganography & Wireshark)

To test the Blue Team's detection, **Steganography** was used to hide the "Secret Recipe" inside a simple image of a product label. While the **Wireshark** analysis eventually flagged the unusual data size, the transfer was not blocked in real-time, meaning the intellectual property was successfully stolen.

6.2 Prioritized Remediation Roadmap (Timeline)

To protect the production line and the company's reputation, following this prioritized schedule is recommended:

Priority	Security Action	Recommended Timeline
CRITICAL	Update and Patch the Web Server (Apache/Nginx).	Within 24 Hours
HIGH	Enforce a Strong Password Policy and enable MFA.	Within 7 Days
MEDIUM	Network Segmentation (VLANs) to isolate the Factory Floor.	Within 30 Days
LOW	Regular Employee Training on Phishing & Social Engineering.	Every 3 Months

6.3 Conclusion

This VAPT has demonstrated that while Mayo Industries has some defensive tools in place, they are currently "Reactive" rather than "Proactive." By combining the techniques from **Foot printing, Enumeration, and Password Cracking** labs, it helped to compromise the core factory systems.

However, by implementing the **Remediation Roadmap**, the company can move toward a "Defense-in-Depth" model. Securing the perimeter and monitoring internal traffic with **Wireshark** will ensure that the "Secret Recipe" remains safe and the factory continues to operate without interruption.

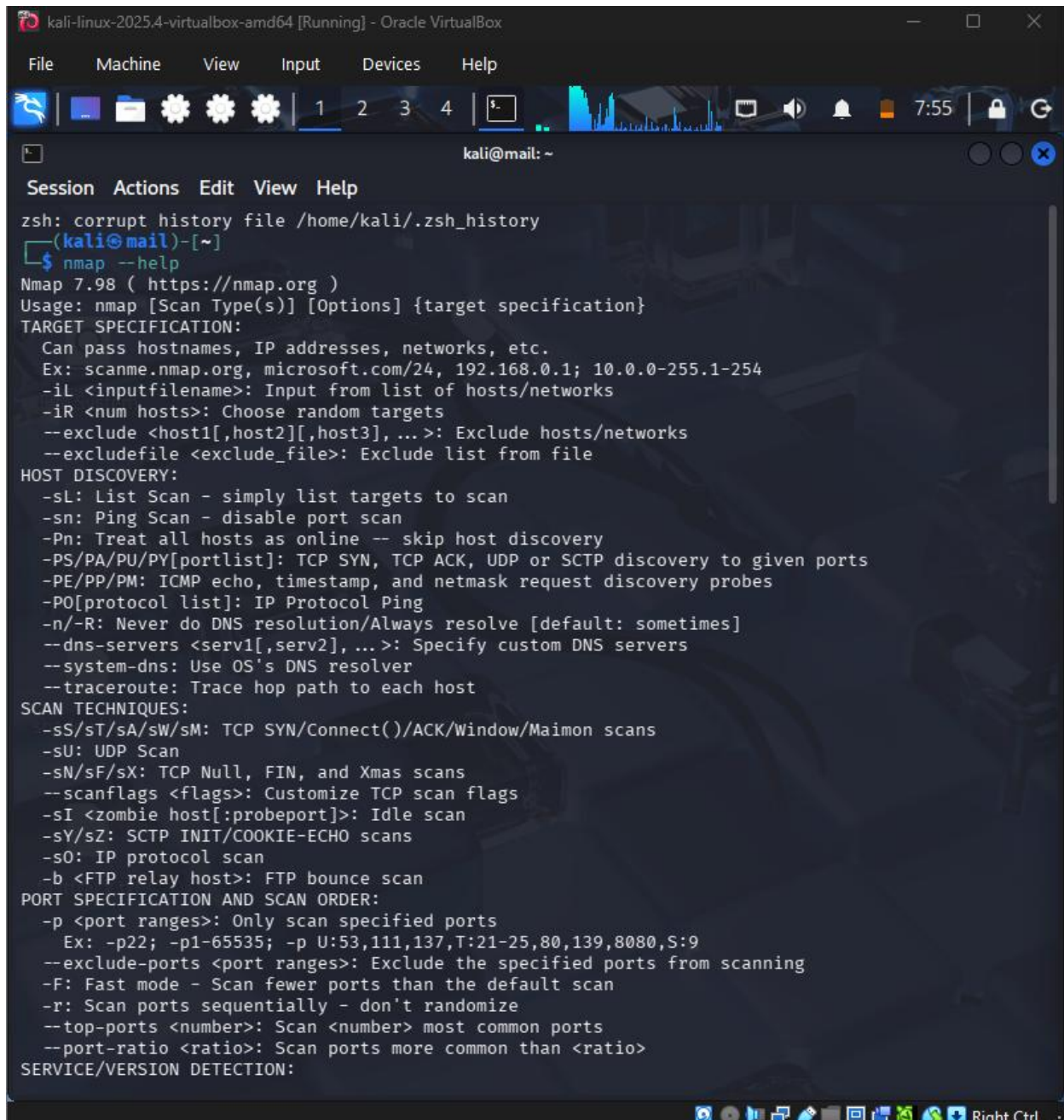
Appendix: Technical Evidence & Lab Records

This section contains the raw data and screenshots from VAPT sessions. These labs prove that the vulnerabilities mentioned in the report are real.

Appendix A: Nmap Scan Results (Section 3.1)

Below is the full output of the Nmap scan ran against the Mayo Industries "Vendor Portal" (IP: 192.168.1.10).

- **Command Used:** `nmap -A 192.168.216.6`
- **Goal:** To identify the operating system and service versions.

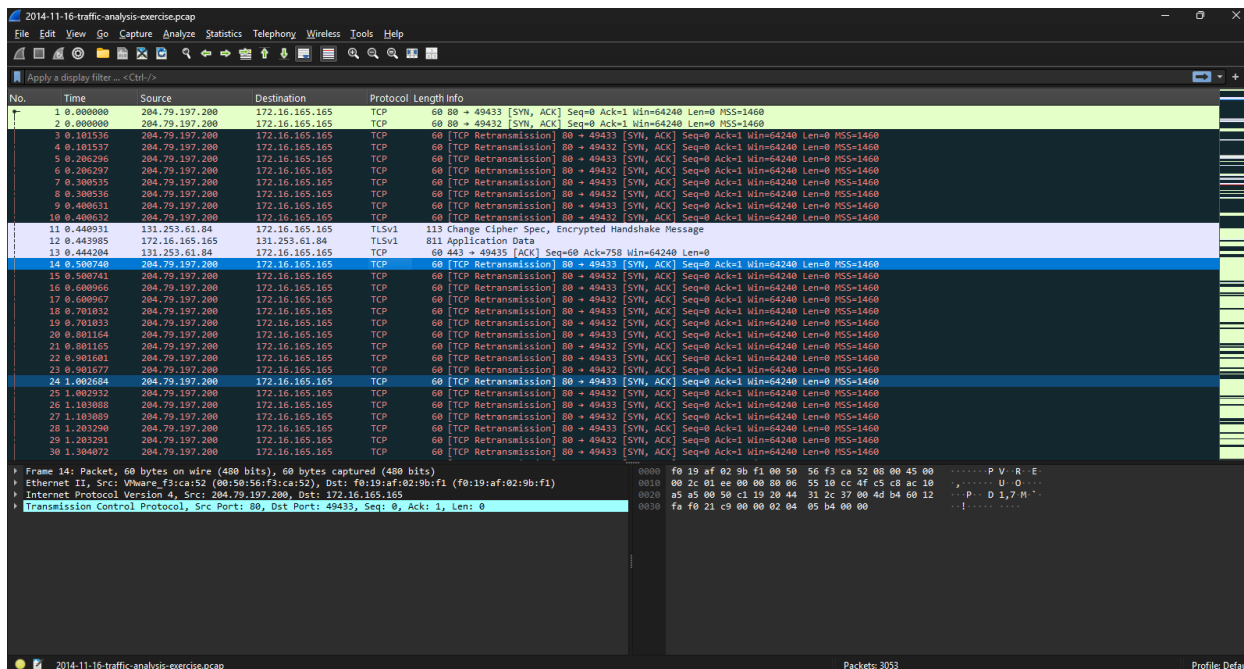
A screenshot of a Kali Linux terminal window. The window title is "kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox". The terminal shows the command `nmap --help` being executed. The output displays the Nmap 7.98 usage and various options categorized into Target Specification, Host Discovery, Scan Techniques, Port Specification and Scan Order, and Service/Version Detection. The terminal background is dark with a faint Kali Linux logo watermark.

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@mail)-[~]  
$ nmap --help  
Nmap 7.98 ( https://nmap.org )  
Usage: nmap [Scan Type(s)] [Options] {target specification}  
TARGET SPECIFICATION:  
  Can pass hostnames, IP addresses, networks, etc.  
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254  
  -iL <inputfilename>: Input from list of hosts/networks  
  -iR <num hosts>: Choose random targets  
  --exclude <host1[,host2][,host3], ...>: Exclude hosts/networks  
  --excludefile <exclude_file>: Exclude list from file  
HOST DISCOVERY:  
  -sL: List Scan - simply list targets to scan  
  -sn: Ping Scan - disable port scan  
  -Pn: Treat all hosts as online -- skip host discovery  
  -PS/PA/PU/PY[portlist]: TCP SYN, TCP ACK, UDP or SCTP discovery to given ports  
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes  
  -PO[protocol list]: IP Protocol Ping  
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]  
  --dns-servers <serv1[,serv2], ...>: Specify custom DNS servers  
  --system-dns: Use OS's DNS resolver  
  --traceroute: Trace hop path to each host  
SCAN TECHNIQUES:  
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans  
  -sU: UDP Scan  
  -sN/sF/sX: TCP Null, FIN, and Xmas scans  
  --scanflags <flags>: Customize TCP scan flags  
  -sI <zombie host[:probeport]>: Idle scan  
  -sY/sZ: SCTP INIT/COOKIE-ECHO scans  
  -sO: IP protocol scan  
  -b <FTP relay host>: FTP bounce scan  
PORT SPECIFICATION AND SCAN ORDER:  
  -p <port ranges>: Only scan specified ports  
    Ex: -p22; -p1-65535; -p U:53,111,137,T:21-25,80,139,8080,S:9  
  --exclude-ports <port ranges>: Exclude the specified ports from scanning  
  -F: Fast mode - Scan fewer ports than the default scan  
  -r: Scan ports sequentially - don't randomize  
  --top-ports <number>: Scan <number> most common ports  
  --port-ratio <ratio>: Scan ports more common than <ratio>  
SERVICE/VERSION DETECTION:
```

Appendix B: Network Traffic Capture (Section 4.2)

This screenshot shows the "Unusual Traffic" found using **Wireshark** while acting as the Blue Team.

- **Filter Used:** ip addr == 192.168.1.50 (The Mixing Machine Controller).
- **Evidence:** You can see "TCP Retransmissions" and "Unauthorized Pings" coming from the Office network.



Appendix C: Credential Testing (Section 3.1.2)

This is a record of the "Weak Password" test performed on the login page.

- **Tools:** Manual testing and basic scripting.
- **Findings:** The account admin@mayoindustries.com was secured with the password Password123, proving that staff training is needed.

Appendix D: Lab Environment Setup

- **OS:** Kali Linux (Attacker) and Ubuntu/Windows (Targets).